



Format String



Bối cảnh (Context)

Phần mềm quản lý nhật ký hệ thống nhận một chuỗi từ người dùng và phản hồi lại câu "Đã ghi nhận: ". Mã nguồn C của phần mềm được viết rất ngắn gọn: `printf(user_input);` thay vì chuẩn mực `printf("%s", user_input);`.

Biến lưu trữ Flag được nạp sẵn vào một biến toàn cục hoặc cục bộ trong bộ nhớ khi chương trình vừa khởi chạy.



Mục tiêu (Objective)

- **Nhiệm vụ:** Đọc được dữ liệu bí mật đang lưu trong bộ nhớ hoặc ghi đè một giá trị để thay đổi quyền kiểm soát.
- **Vấn đề / Lỗ hổng: Format String Vulnerability.** Khi người dùng kiểm soát chuỗi định dạng, họ có thể nhập các ký tự đặc biệt như `%x`, `%p` để rò rỉ (leak) dữ liệu từ Stack, hoặc `%n` để ghi một giá trị tùy ý vào một địa chỉ trong bộ nhớ. Điều này giúp đọc file bộ nhớ hoặc đổi hướng thực thi của chương trình.
- **Flag:** Tìm Flag trong bộ nhớ bị rò rỉ.



Gợi ý (Hints)

- Hãy thử nhập `%p %p %p %p` và xem chương trình in ra những con số Hexadecimal khó hiểu. Đó chính là bộ nhớ Stack.
- Bạn có thể truyền thứ tự để đọc một vị trí cụ thể, ví dụ `%10$p` để xem giá trị thứ 10 trên Stack.